Figure 13.2 C³ authorization flow through global and tenant PEP/PDP layers

This figure traces a single authorization request moving through the C³ platform. The numbered circles correspond to these steps:

1. **Initial request**. A user—either an ACME employee or a tenant customer—initiates an API call from the client. The request includes an OIDC access token (and, for ACME employees, a device-posture token).
2. **Normalized request**. The ACME Gateway, serving as the global PEP, verifies both tokens, extracts identity and context, and builds a PARC-structured authorization request (principal, action, resource, context).
3. **Global decision**. The normalized request is sent to the C³ PDP, which evaluates ACME's global governance policies for tenant isolation, data residency, and device compliance. The PDP returns either `permit` or `forbid`.
4. **Enforce global policy**. If the decision is `forbid`, the ACME Gateway blocks the request. If the decision is `permit`, the gateway forwards the normalized request to the appropriate tenant PEP, scoped to that tenant's namespace. The decision is recorded in global audit logs
5. **Tenant request**. The tenant PEP receives the permitted request and makes its own policy evaluation call to the tenant's PDP (shared or dedicated instance).
6. **Tenant decision**. The tenant PDP evaluates the tenant's ReBAC policies and responds with `permit` or `forbid`.
7. **Enforce tenant policy**. The tenant PEP enforces the result locally and records it in the tenant audit log. A `forbid` decision ends the flow; a `permit` proceeds to resource processing.
8. **Processing**. Authorized actions run within the tenant's workspace. The application code can assume that access has already been verified.
9. **Response**. The service provides the application's response to the client. Both global and tenant layers generate audit entries, ensuring every decision is traceable.

Together, these steps show how each authorization in C³ passes through two enforcement layers: